

Musterlösungen Fallbeispiel «Mobirama – Hacker Angriff»

- Prinzipiell gilt es die Antworten zu begründen. Ja/Nein und eine kurze Begründung zur Nachvollziehbarkeit.
- Wo Angaben fehlen, muss eine plausible Annahme getroffen und diese kurz begründet werden.

Tag 1

Analyse – Fragen

1. Welche Risiken könnten für den Betrieb relevant sein? Wie hoch ist die Eintrittswahrscheinlichkeit und der potenzielle Schaden? (Risiko Matrix für 4 Risiken)

Risiko	Wahrscheinlichkeit	Schaden
Brand	Hoch (Maschinen, Sägemehl, Holz etc.)	Sehr hoch
Wasserschaden	Gering	Wenn IT-Raum betroffen: hoch, Sonst eher gering
Sabotage	Gering	Mittel bis sehr hoch
Ransomware	Mittel bis hoch	Sehr hoch
Insider Attacke	Gering	Mittel bis sehr hoch
Stromausfall	Mittel	Auf IT-bezogen: Gering, da sowieso niemand mehr arbeiten kann Allgemein: Potenziell hoch, da Maschinen Aufträge am Bearbeiten sind
Allgemeine Cyber-Attacke	Mittel	Gering bis sehr hoch
Datenverlust	Mittel	Gering bis sehr hoch
Prinzipiell alle möglichen Risiken nach dem «Risikokatalog»		

2. Welches Risiko ist eingetroffen?
 - Ransomware
3. Situationseinschätzung: Wie wahrscheinlich ist es, dass das eingetroffene Risiko im Konzept beachtet wurde? Begründen!
 - Wahrscheinlich wurde für die Auslagerung das Risiko «Brand» angenommen, daher eine Auslagerung auf Tape wobei bis zu 1 bzw. 2 Wochen Datenverlust in Kauf genommen wurde. Wäre das Risiko Ransomware im Fokus gewesen, dann wäre sicher die RPO/RTO tiefer gewesen (RPO: In diesem Kontext, der maximale Datenverlust von 7 Tage, RTO: Die Zeit, die für die Wiederherstellung maximal zur Verfügung steht z.B. 3 Tage)
4. Welche Auswirkung hatte der Vorfall auf den operativen Betrieb?
 - Daten für Bearbeitung der Aufträge fehlten
 - Maschinen funktionierten nicht mehr
 - Der operative Betrieb stand still
5. Welcher Schaden ist entstanden – Schätzung des Schadens
 - Unteren fünfstelligen Bereich (Schätzung: 10'000 – 30'000CHF)
 - 1.12.2017 = Freitag. Somit 1 Tag Ausfall = 10'000 – 30'000CHF

Tag 2

Analyse – Fragen

1. Welche Daten sind in der Unternehmung vorhanden? Welche wurden gesichert?
 - a. Kundendaten
 - b. Baupläne
 - c. OS, Applikationsdaten (z.B. Steuerung der CNC Maschinen)
 - d. Annahme: Buchhaltung
2. Was kann aus dem Text zu folgenden Punkten abgeleitet werden?
 - a. RPO/RTO
 - i. Nicht ersichtlich. Wenn jedoch wöchentlich eine Datensicherung ausgelagert wurde, beträgt die RPO mindestens 7 Tage
 - b. Sicherungsart
 - i. Am wahrscheinlichsten: Full (Wöchentlich) + inkrementell
 - c. Verfügbarkeit
 - i. Bei diesem KMU ist eine Verfügbarkeit während der Geschäftszeit auszugehen (z.B. 08:00 – 17:00)
 - d. Lagerung der Sicherung
 - i. Eine Sicherung vor Ort
 - ii. Eine Sicherung ausgelagert (Standort nicht weiter spezifiziert)
 - e. 3-2-1 Regel
 - i. 3: unklar, 2: unklar, 1: Ja, Auslagerung auf Band
3. Wie hoch ist der Datenverlust (Stunden/Tage)? Warum konnte dieser nicht minimiert werden? Wo steckte der «single point of failure» des kompletten Konzepts bzw. dessen Umsetzung?
 - a. Der Datenverlust beträgt eine komplette Arbeitswoche
 - b. Singlepoint of failure: Die Auslagerung wurde nur wöchentlich durchgeführt. Da das Risiko nun am Freitag eintraf, traf zugleich der fast grösst mögliche Schaden ein (4 von 5 Arbeitstagen)
4. Gilt dieses Fallbeispiel eher als Backup (Restore) oder als DR-Fall? (was eher zutrifft)
 - a. DR: Die komplette Umgebung und somit auch alle Services waren nicht mehr verfügbar
5. Wie überschneiden sich in diesem Beispiel DR/Backup?
 - a. Das Backup und DR Szenario nutzen die gleichen Speichermedien und Backup-Datenbestände.

Tag 3

Analyse – Fragen

1. Medien
 - a. Welche Medien wurden eingesetzt?
 - i. Tape
 - b. Welche Vorteile und Herausforderungen ergeben sich daraus?
 - i. Vorteil: kann ausgelagert werden
 - ii. Nachteil: Eine Auslagerung ist mit manuellen Prozessen verbunden, dadurch fehleranfällig (Dies spezifisch auf dieses Fallbeispiel)
 - iii. Weitere Nachteile: Medium könnte während der Auslagerung verloren gehen, Auslagerung nicht 24/7 in kurzen Intervallen möglich
 - c. Wurden damit alle Punkte aus der 3-2-1-(0) Regel umgesetzt? Zeige dies auf und erläutere/begründe dies.
 - i. Sehr wahrscheinlich wurde nur ein einziges Backup auf Tape erstellt und Ende Woche ausgelagert. Somit ist davon auszugehen, dass zumindest «1+» eingehalten wurde. Eine weitere Annahme ist, dass sowohl «3» wie auch «2» nicht eingehalten wurden, sonst wären gewisse Restore-Punkte einfacher / Schneller gewesen (z.B. Baremetal Restore)
 - d. Was für eine Auswirkung hat das gewählte Medium auf die aktuelle RPO/RTO?
 - i. Tape: RPO und RTO können nicht beliebig minimiert werden. Bei RPO ist es unwahrscheinlich, dies unter 24h zu bringen (dies würde bereits eine Auslagerung pro Tag bedingen). RTO: Zuerst müssen alle benötigten Tapes zurückgeholt, danach die Daten gelesen und eingespielt werden. Somit ist es unwahrscheinlich, eine RTO unter 1 Tag anzusetzen. Wenn die Tapes noch auf einer Bank sind, wird von Freitag bis Sonntag kein Zugriff möglich sein. Somit müsste die RTO über 2 Tage liegen.
 - e. Wäre eine kleinere RPO/RTO realistisch gesehen umsetzbar gewesen?
 - f. Was wäre mit diesem Medium die kleinstmögliche RPO/RTO die effektiv umgesetzt werden kann?
2. Erläutere, was für Medien als Alternative sinnvoller gewesen wären und begründe dies. Was für eine RPO/RTO wäre damit realistisch gesehen umsetzbar?
 - a. Siehe Block 3 mit Speichermedien
 - b. Prinzipiell: Für kleines KMU mit wenig Daten wäre eine Cloud-Lösung für die Backupauslagerung sicher zielführender gewesen.
 - c. RPO: <5min möglich, RTO <x h möglich.
 - d. RTO: Abhängig von der Datenmenge und Internet Downlink. Bei 1Gbit/s wären über 300GB pro Minute möglich. Somit realistisch: 1-8h bei dieser KMU Grösse (Annahme: 1-2 TB Daten die für ein DR nötig wären)
3. Automatisierung
 - a. Wie viel der aktuellen Lösung ist (unter gleichbleibenden Bedingungen) automatisierbar?
 - i. Durchführung der täglichen Backups
 - ii. Backup Tests, sofern für das primäre Backup nicht Tape verwendet wurde.
 - b. Welche Teile des Prozesses sind nicht automatisierbar und weshalb?
 - i. Auslagerung der Tapes: Da das Medium physisch von A nach B transportiert werden muss, wird dies in naher Zukunft immer von einer Person durchgeführt
 - c. Was müsste geändert werden, damit dies automatisierbar ist?
 - i. Die primäre Auslagerung müsste auf ein «online» Medium geschehen. Theoretisch könnte dies auch an einen zweiten Standort der Unternehmung sein, wenn nur «1» im Fokus steht. Wenn dies mit einem Ransomware-Schutz ergänzt wird, müsste dies fast über eine «Cloud Lösung» ausgelagert werden

Tag 4

Analyse – Fragen

1. Technologie
 - a. Welche Technologien wurden eingesetzt?
 - i. Wahrscheinlich ein Agent-basiertes Backup (Steuerungscomputer der CNC Maschine)
 - ii. Server: Sehr wahrscheinlich auch Agent-basiert (Fokus auf Daten)
 - iii. Begründung: Wäre ein API-basiertes Backup von VMs vorhanden (OS+Apps+Daten), dann wäre ein Restore viel schneller durchgeführt gewesen
 - b. Welche Vorteile und Herausforderungen ergeben sich daraus?
 - i. Vorteile:
 1. Bei einem Agent-basierten Backup ist es meistens möglich, ein komplettes Abbild des physischen Gerätes zu erstellen (OS, Apps, Daten).
 2. Agent basierte Backups können sowohl zentral auch dezentral gesteuert werden
 3. Wenn Punkt1 eingehalten wurde: Baremetal Recovery möglich
 - ii. Herausforderungen
 1. Agents müssen auf aktuellem Stand sein. Wartung / Updates etc. der Agents haben eine Auswirkung auf den PC / Server etc.
 2. Damit ein Backup durchgeführt werden kann, muss das Gerät eingeschaltet sein
 3. Bei Admin-Zugriff auf das Gerät könnte je nach Verwaltung bzw. bei einer dezentralen Verwaltung eine Anpassung direkt am Agenten vorgenommen werden, die nicht erwünscht ist (z.B. Ausschluss von Daten aus dem Backup, böswillige Manipulation)
 4. Damit ein Baremetal Restore möglich ist, muss dies explizit unterstützt und getestet werden (Änderungen an Treibern könnte dazu führen, dass dies fehlschlägt ->aktuelles Recovery Image muss vorhanden sein)
2. Backupart
 - a. Welche wurde eingesetzt?
 - i. Wahrscheinlich Full + Incrementell.
 - b. Macht diese Art mit den vorhandenen Technologien Sinn? Würden Sie etwas ändern (wenn ja: was)?
 - i. Sinnvoll: Ja, damit immer ein Full für die Tape Auslagerung vorhanden ist. Aber: Ein tägliches Full hätte den vorteil, das täglich ein Fullbackup auf Tape geschrieben wird.
 - c. Was für eine Auswirkung hätte die Änderung auf «Incremental Forever» auf das bestehende Konzept bzw. auf die eingesetzte Technologie?
 - i. Wenn das Backup direkt auf Tape geschrieben wird, wäre dies nicht umsetzbar
 - ii. Wenn das Backup zuerst auf Disk und dann auf Tape geschrieben wird, wäre dies kein Problem.
 - d. Was müsste angepasst werden um «Incremental Forever» umzusetzen?
 - i. Das Backup dürfte nicht direkt auf Tape geschrieben werden

Tag 5

Analyse – Fragen

3. Datenvolumen

- a. Wie gross ist die Source Datenmenge?
 - i. Annahme: Wenige TBs. Z.B. 2TB
- b. Wie gross wird die tägliche Änderungsrate sein?
 - i. Wenige Prozent (z.B. 5-10%). Realistisch werden 5% sein, knapp 100GB (5% von 2TB).
- c. Schätze eine Komprimierungsrate, die Du bei einem solchen Konzept festlegen und für ein Sizing verantworten könntest. Was hat eine zu grosse und eine zu kleine Annahme für eine Auswirkung auf das Konzept? Welche der beiden Varianten wäre kritischer?
 - i. Schätzung: 1:2 (50%) ist meistens realistisch
 - ii. Zu gross: z.B. 1: 3 (ca. 66%) -> hier wird mit einer zu grossen Reduktion gerechnet. Das führt dazu, dass zu wenig Speicherplatz eingeplant wird (Speicherplatz könnte ausgehen)
 - iii. Zu klein: z.B. 1:1.1 (ca. 10%) -> Hier wird mit einer zu kleinen Reduktion gerechnet. Das führt dazu, dass zu viel Speicherplatz eingeplant wird (brachliegende Ressourcen).
 - iv. Kritischer: zu wenig Speicherplatz, somit die Schätzung der zu grossen Datenreduktion
- d. Wie gross wird ein Full und ein inkrementelles Backup sein?
 - i. Bei dieser Annahme: 2TB, 5% = 0.1TB
- e. Wie gross wird die gesamte Backupdatenmenge sein? Aus was setzt sich diese zusammen?
 - i. Dies kommt auf die Aufbewahrungszeit an.
 - ii. Zusammensetzung: $\text{AnzahlFullbackups} \times 2\text{TB} + \text{AnzahlDeltas} \times 0.1\text{TB} = \text{Totale Datenmenge für lokales Backup}$ (Achtung: Dies beinhaltet weder eine zusätzliche Kopie noch die Auslagerung und dient als Ausgangslage)

4. Performance

- a. Wie hoch muss die Schreib- und Lesegeschwindigkeit fürs Backup mindestens sein, damit die definierten SLAs eingehalten werden?
 - i. Dafür muss zuerst eine SLA definiert werden. Annahme: 8h Zeitfenster fürs Backup. $2\text{TB Fullbackup} / 8\text{h} = \text{ca. } 72\text{MB/s}$
 - ii. RTO: Gleiches vorgehen. $\text{Fullrestore } 2\text{TB} / x\text{h} = x \text{ MB/S}$. Annahme: Dies wird grösser wie 8h sein, daher reichen die 72MB/s vom Backup Windows als Anforderung für die Lesegeschwindigkeit.
- b. Welche Komponenten sind alle daran beteiligt und müssen eine entsprechende Performance ausweisen?
 - i. Lokale Geräte (Steuerung CNC): Disk Performance, CPU Performance, genügend RAM (CPU+RAM für die Bearbeitung des Backups), Netzwerk für die Übertragung, Backup Server (CPU, RAM, Netzwerk, Disks), Tape-Drive und Tape-Kassette
- c. Was könnte sonst noch eine Auswirkung auf die Performance des Backups haben, obwohl es nicht oder nicht direkt zur Backup Infrastruktur gehört und weshalb?
 - i. Der Produktive Betrieb.
 1. Angenommen, die CNC Steuerung arbeitet, während das Backup durchgeführt wird, wird auch eine gewisse Performance für den produktiven Betrieb benötigt.
 2. Gleiches Beispiel bei einem File-Server: Die User möchten ohne negative Auswirkung des Backups weiterarbeiten können. Z.B. sollte das Backup das Netzwerk auslasten, haben die User erhöhte Latenzen und alles fühlt sich «langsamer» an.
 3. Beispiel File-Server2: Angenommen, der Fileserver ist sehr stark ausgelastet (z.B. Disks, SATA-HDDs), führt dies ebenfalls zu einer sehr hohen Latenz beim Datei-Zugriff

Tag 6

Analyse – Fragen

1. Allgemein
 - a. Beurteile das Konzept auf folgende Punkte: Umsetzbarkeit, Komplexität
 - i. Umsetzbarkeit: Ja
 - ii. Komplexität: Nein (sehr rudimentär)
 - iii. Achtung: Umsetzbarkeit nicht mit Sinnhaftigkeit vergleichen. Die Frage zielt nur darauf ab, ob dies in der Praxis umsetzbar ist. Das Konzept selbst weist definitiv Defizite auf und hat Verbesserungspotenzial
2. DR Konzept
 - a. Was für ein DR Plan wurde umgesetzt? Beschreibe den Plan/Prozess.
 - i. Annahme:
 1. Tapes wurden von externem Standort abgeholt und in die Schreinerei gebracht
 2. Alles wurde neu installiert
 3. Daten wurden in die jeweilige Applikation zurückgespielt
 4. Testen und Verifizieren
 5. Anmerkung: Task 1 und 2 könnten parallel durchgeführt worden sein. Task 3 und 4 könnten pro Applikation nacheinander durchgeführt worden sein
 - ii. Begründung: Wäre ein Baremetal Recovery möglich gewesen, hätte es nicht so lange gedauert.
 - b. Konnte der Plan/Prozess erfolgreich umgesetzt werden? Gab es Schwierigkeiten, wenn ja: welche?
 - i. Erfolgreiche Durchführung: Ja
 - ii. Schwierigkeiten: Eine Arbeitswoche an Daten gingen verloren
 - iii. Abhängigkeit zu IT-Dienstleister
3. Single Point of Failure
 - a. Welcher Punkt ging im Konzept grundsätzlich komplett vergessen? Welche Punkte wurden nicht komplett umgesetzt?
 - i. Komplette vergessen: Was passiert, wenn am letzten Tag der Woche ein kompletter Datenverlust passiert? -> 5 Tage Datenverlust
 - ii. Ransomware als Risiko
 - iii. Wahrscheinlich eine RTO Einschätzung. Die IT war fast 3 Tage dran (Fr, Sa, So). Was wäre passiert, wenn das Risiko am Mittwoch eingetroffen wäre?
 - iv. DR: Bare Metal Recovery
 - b. Was hatte dies für eine Auswirkung?
 - i. Der Schaden wäre noch viel grösser, da zusätzlich noch 3 Tage nicht gearbeitet werden konnte
 - c. Wie hätte dies bemerkt und somit proaktiv korrigiert werden können?
 - i. Eine klare Anforderung mit definierter SLA
 - ii. Dann hätte z.B. auch am Mittwoch ein Tape ausgelagert werden können
 - iii. Umsetzung des Bare Metal Recovery

4. Skalierbarkeit

- a. An welche Grenzen könnte das Konzept/die Umsetzung stossen?
 - i. Wenn ein single Tape Drive im Einsatz ist: Die maximale Grösse einer Tape-Kassette
- b. Annahme: Die Source Daten wachsen um den Faktor (a) 10, (b) 20, (c) 100. Was hätte dies für eine Auswirkung? Wie könnte bei der aktuellen Umsetzung damit umgegangen werden?
 - i. Prinzipiell würde bei allen Varianten mehr als ein Tape benötigt werden. Annahme: Da dies im Jahr 2017 geschah, wurde wahrscheinlich LTO6 (2.5TB Kapazität) oder LTO7 (6TP Kapazität) eingesetzt
 - ii. Grundlegend: Es könnten mehrere Tapes beschrieben werden
 - iii. Praxis: Bei allen Beispielen wäre es mit einem single Tapedrive nicht mehr realistisch umsetzbar gewesen. Somit hätte eine Tapelibrary besorgt werden müssen.
- c. Was für ein DR Plan wurde umgesetzt?

5. Architektur

- a. Erarbeite 2 Alternativen und zeichne sie schematisch.
- b. Erläutere deren Vorteile und Herausforderungen sowie die minimalst möglichen RPO/RTO.
- c. Wie unterscheiden sich die beiden Varianten bezüglich der Umsetzbarkeit und der Komplexität?
- d. Musterlösung Aufgabe 5: Prinzipiell ist jede Lösung akzeptabel, solange sie folgende Punkte enthält
 - i. Klare definierte SLA (RTO, RPO, Aufbewahrungszeit)
 - ii. Klare Erläuterung der Vor- und Nachteile
 - iii. Möglichkeit zur Skalierung die sinnvoll erscheint (z.B. statt 10 neu 100Tapes einsetzen ist weder sinnvoll noch umsetzbar)
 - iv. Klare Einhaltung der 3-2-1 Regel inklusive Ransomware Schutz
 - v. RPO -> Datenverlust darf nicht über 24h liegen. Die Lösung muss eine Möglichkeit beinhalten, wie die Daten automatisiert ausgelagert werden. Selbstverständlich darf Tape zusätzlich immer noch im Einsatz sein
 - vi. Backup to Disk: Das erste Backup wird immer auf Disks geschrieben. Falls Tape eingesetzt wird: Erst als zweite Kopie werden die Daten auf Tape geschrieben